CALDERWICK PUMP SYSTEMS LTD

IT Security Policy, Version 2

Document code	IT-SEC-02
Version	2.0
Effective date	1 March 2025
Owner	Information Security Officer
Approved by	Head of IT
Replaces	IT-SEC-01 (2022)
Classification	Internal

1. Purpose and scope

This policy protects the information and systems of Calderwick Pump Systems Ltd. It covers office IT systems, the Ledgerline ERP, email and file shares, and the operational technology (OT) that runs our plants, including the control systems of the Ardmoor test rigs and the Fenwick Bay furnace. It applies to employees, contractors and suppliers who use or connect to Calderwick systems.

2. Roles

Table 1 - Roles

Role	Responsibility
Head of IT	Accountable for information security; approves this policy and any exceptions
Information Security Officer	Owns this policy; runs access reviews; leads the response to security incidents
IT Service Manager	Runs the service desk, incident management and the Change Advisory Board
OT Systems Engineer	Manages plant control systems and approves supplier remote sessions to them
Line managers	Request and remove access for their teams; confirm access in reviews
All users	Follow this policy and report incidents at once

3. Information classification

Table 2 - Classification

Class	Examples	Handling
Public	Published product data sheets	No restrictions
Internal	Policies, staff directory, plant reports	Calderwick staff and contractors only

Class	Examples	Handling
Confidential	Contracts, financial reports, customer test results	Need-to-know; encrypted when sent outside Calderwick
Restricted	Payroll data, board papers before release, security configurations	Named people only; never on personal devices

4. Access control

Access is given on the principle of least privilege: only the access a person needs for their role. Line managers request access for new starters and changes through the service desk. When a person leaves, their accounts are disabled at the end of their last working day; line managers raise the leaver request at least five working days before.

Administrator (privileged) access uses separate accounts that are not used for email or browsing. The Information Security Officer reviews all user, privileged and supplier accounts every quarter and reports the results to the Head of IT. Access that is no longer needed is removed within five working days of the review.

5. Passwords and authentication

- Passwords have at least 14 characters and are not reused from the last 10 passwords.
- Accounts lock after 10 failed sign-in attempts.
- Multi-factor authentication is required for all remote access, all administrator access and the Ledgerline ERP.
- Passwords are never shared, written down near a device or sent by email.

6. Remote access and suppliers

Employees connect remotely through the Calderwick VPN with multi-factor authentication. Suppliers never connect directly to Calderwick networks: they use the Calderwick jump host, which records every session.

A supplier session to a plant control system must be approved for that session by the OT Systems Engineer, who records the supplier, the system, the reason and the times. Supplier accounts expire after 90 days and are renewed only on the request of the contract owner.

7. Plant control (OT) systems

- OT networks are separated from the office network by firewalls; traffic between them is limited to named services.
- OT systems have no direct internet access.
- USB ports on rig and furnace controllers are disabled.
- Changes to controller firmware or configuration go through change management and are tested on one rig or unit before others.
- Controller configurations are backed up after every change.

8. Change management and patching

Changes to production systems, including patches and updates applied by suppliers, need approval of the Change Advisory Board (CAB) before they are made, except for emergency changes approved by the IT Service Manager. The CAB meets weekly and is chaired by the IT Service Manager.

Table 3 - Patching deadlines

System type	Critical security patches	Other patches
Office IT and business systems	Within 14 days of release	Within 60 days
OT systems	Within 30 days or at the next planned maintenance window, whichever is first	At the next planned maintenance window

9. Backups

Business systems are backed up daily and daily backups are kept for 35 days; monthly backups are kept for 12 months. A restore test of at least one business system is done every quarter. Recovery targets for each system are set in the Disaster Recovery Plan (IT-DRP-01).

10. Incidents

Report every IT incident to the service desk. Suspected security incidents, such as phishing, malware or lost devices, are reported at once and passed to the Information Security Officer within one hour. Any incident that may involve personal data is reported to the General Counsel within 24 hours.

Internal IT incidents are prioritised as follows. Incidents on the Ardmoor test rigs use the priorities and times of the maintenance contract with the rig supplier, not this table.

Table 4 - IT incident priorities

Priority	Meaning	Response	Restore target
P1	Business-critical system unavailable for all users	30 minutes	4 hours
P2	Business-critical system degraded, or unavailable for some users	2 hours	8 hours
P3	Non-critical system affected	1 business day	3 business days
P4	Request or minor fault	3 business days	10 business days

11. Acceptable use

Calderwick devices and accounts are for business use. Limited personal use is allowed as described in the Employee Handbook. Users must not install unapproved software, disable security tools, or store Calderwick data in personal cloud services.

12. Exceptions

An exception to this policy must be requested in writing, explain the risk and the compensating controls, and be approved by the Head of IT. Exceptions last at most six months and are recorded by the Information Security Officer.

13. Training

All users complete security awareness training every year. Everyone with access to plant control systems also completes OT security awareness every year.

14. Compliance and review

Breaches of this policy may lead to disciplinary action or, for suppliers, to the end of their access and contract. The Information Security Officer reviews this policy every year.